



PERFORMANCE WORK STATEMENT (PWS) DEPARTMENT OF VETERANS AFFAIRS

**Veterans Health Administration (VHA)
National Teleradiology Program (NTP)
Teleradiology Physician Services**

**Date: TBD
PWS Version Number: 1**

CONTENTS

1.0	BACKGROUND.....	3
2.0	APPLICABLE DOCUMENTS.....	3
3.0	SCOPE OF WORK.....	7
4.0	PERFORMANCE DETAILS.....	8
4.1	CONTRACT TYPE.....	8
4.2	PERFORMANCE PERIOD	8
4.3	PLACE OF PERFORMANCE	8
4.4	VA HOURS OF OPERATION	8
5.0	SPECIFIC TASKS AND DELIVERABLES	8
5.1	SERVICE MANAGEMENT.....	9
5.1.1	CONTRACTOR PROJECT MANAGEMENT PLAN	9
5.1.2	DIRECT PATIENT CARE – TELERADIOLOGY	9
5.1.3	CONTRACTOR RESPONSIBILITIES.....	10
5.1.4	CONTINUITY OF SERVICES UNDER CONTRACT	17
5.1.5	CONTRACTOR RESPONSIBILITIES.....	18
5.1.6	MEDICAL RECORDS.....	19
5.1.7	SYSTEM REQUIREMENTS	21
5.1.8	GOVERNMENT RESPONSIBILITIES	23
5.1.9	REPORTING REQUIREMENTS.....	25
5.1.10	QUALITY CONTROL.....	26
5.1.11	SECURITY AND PRIVACY REQUIREMENTS.....	26
6.0	VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE FOR INCLUSION INTO CONTRACTS, AS APPROPRIATE	28
1.	GENERAL	28
2.	ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS	28
3.	VA INFORMATION CUSTODIAL LANGUAGE.....	29
4.	INFORMATION SYSTEM DESIGN AND DEVELOPMENT	31
5.	INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE, OR USE.....	34
6.	SECURITY INCIDENT INVESTIGATION	37
7.	LIQUIDATED DAMAGES FOR DATA BREACH.....	37
8.	SECURITY CONTROLS COMPLIANCE TESTING.....	39
9.	TRAINING.....	40

1.0 BACKGROUND

The mission of the Department of Veterans Affairs (VA), Veterans Health Administration (VHA) is to provide benefits and services to Veterans of the United States, their caregivers, and/or beneficiaries. The Department of Veterans Affairs (VA), Veterans Health Administration (VHA), National Teleradiology Program (NTP) provides high-quality, effective, and efficient solutions to those responsible for providing care to the Veterans at the point-of-care as well as throughout all the points of the Veterans' health care in an effective and timely manner.

The NTP provides teleradiology services to more than 130 VHA facilities across the United States. Due to recent staffing losses and a national shortage of radiologists, NTP has been unable to recruit enough new radiologists to meet current workload demands. NTP is seeking a contract for teleradiology services to meet and support workload demands.

2.0 APPLICABLE DOCUMENTS

Policy/Directives/Handbooks. The Contractor shall be subject to the following policies, including any subsequent updates during the period of performance. These policies may be accessed electronically via the following: [VA Publications](#) [VHA Publications](#)

1. VA Directive 1663: Health Care Resources (HCR) Contracting – Buying Title 38 U.S.C. 8153
2. VHA Directive 1003.04: VHA Patient Advocacy
3. VHA Directive 1065: Productivity and Staffing Guidance for Specialty Provider Group Practice
4. VHA Directive 1084: Teleradiology Services
5. VHA Directive 1088(1): Communicating Test Results to Providers and Patients
6. VHA Directive 1100.18: Reporting and Responding to State Licensing Boards
7. VHA Directive 1100.20: Credentialing of Health Care Providers
8. VHA Directive 1100.21: Privileging
9. VHA Directive 1605.01: Privacy and Release of Information
10. VHA Directive 1907.01: VHA Health Information Management and Health Records
11. VHA Directive 1916(1): VHA Teleradiology Programs, dated June 10, 2021.
12. VHA Handbook 1100.17: National Practitioner Data Bank (NPDB) Reports
13. Privacy Act of 1974 (5 U.S.C. 552a) as amended:
http://www.justice.gov/oip/foia_updates/Vol_XVII_4/page2.htm
14. 42 Code of Federal Regulations (CFR) Part 482 Conditions of Participation Hospitals:
<https://www.ecfr.gov/cgi-bin/text-idx?node=pt42.5.482&rgn=div5>
15. The VA Radiology Services follow the standards and guidelines set forth by the American College of Radiology (ACR)
https://gravitas.acr.org/ppts?_gl=1*hstxx2*_gcl_au*MzM1MTE1NjY5LjE3NTk

Teleradiology Physician Services

[0MzUzNzc.*_ga*NzQ3ODczNTAyLjE2OTkzOTA5MjM.*_ga_K9XZBF7MXP*
czE3NjUzOTU0MjMkbzU0JGcwJHQxNzY1Mzk1NDI1JGo1OCRsMCRoMA.](#)

16. "Federal Information Security Modernization Act of 2014"
17. Federal Information Processing Standards (FIPS) Publication 140-3, "Security Requirements for Cryptographic Modules", March 22, 2019
18. FIPS Pub 199. "Standards for Security Categorization of Federal Information and Information Systems," February 2004
19. FIPS Pub 200, "Minimum Security Requirements for Federal Information and Information Systems," March 2006
20. FIPS Pub 201-3, "Personal Identity Verification of Federal Employees and Contractors," January 2022
21. 10 U.S.C. § 2224, "Defense Information Assurance Program", as amended
22. 5 U.S.C. § 552a, as amended, "The Privacy Act of 1974"
23. Public Law 109-461 (P.L. 109-461), Veterans Benefits, Health Care, and Information Technology Act of 2006, as amended, Title IX, Information Security Matters
24. 42 U.S.C. § 2000d "Title VI of the Civil Rights Act of 1964", as amended
25. VA Directive 0710, "Personnel Vetting Program," September 8, 2025, https://www.va.gov/vapubs/viewPublication.asp?Pub_ID=1631&FType=2
26. VA Handbook 0710, "Personnel Vetting Program," September 8, 2025, https://www.va.gov/vapubs/viewPublication.asp?Pub_ID=1631&FType=2
27. VA Directive 6102, "Internet/Intranet Services," August 5, 2019
28. 36 C.F.R. Part 1194 "Information and Communication Technology Standards and Guidelines," as amended
29. Office of Management and Budget (OMB) Circular A-130, "Managing Federal Information as a Strategic Resource," July 28, 2016
30. 32 C.F.R. Part 199, "Civilian Health and Medical Program of the Uniformed Services (CHAMPUS)", as amended
31. NIST SP 800-66 Rev. 2, "Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide," February 2024
32. 45 C.F.R. Parts 160 and 164, Subparts A and E, the Standards for Privacy of Individually Identifiable Health Information ("Privacy Rule"); and 45 C.F.R. Parts 160 and 164, Subparts A and C, the Security Standard ("Security Rule"); as amended
33. Sections 504 and 508 of the Rehabilitation Act (29 U.S.C. § 794d), as amended
34. Homeland Security Presidential Directive (12) (HSPD-12), August 27, 2004
35. VA Directive 6500, "VA Cybersecurity Program," February 24, 2021 (see VA NOTICE 24-18, dated September 27, 2024, "Update to VA Directive 6500 Cybersecurity Program", and VA Notice 25-07, dated 3/18/25, "Amending VA Directive 6500 to incorporate M-24-15")
36. VA Handbook 6500, "Risk Management Framework for VA Information Systems VA Information Security Program," February 24, 2021 (see VA Notice 25-01, dated October 15, 2024, "Update to VA Handbook 6500 Risk Management Framework for VA Information Systems VA Information Security Program", and VA Notice 25-06, dated 3/18/25, "Amending VA Directive 6500 to incorporate M-24-15")
37. VA Handbook 6500.2, "Management of Breaches Involving Sensitive Personal Information (SPI)," June 30, 2023
38. VA Handbook 6500.6, "Contract Security," March 12, 2010 (see VA Notice 24-12, dated April 22, 2024, "Update to VA Handbook 6500.6, Contract Security, Appendix

Teleradiology Physician Services

- C VA Information and Information System Security/Privacy Language For Inclusion Into Contracts, As Appropriate”)
39. VA Handbook 6500.8, “Information System Contingency Planning,” March 25, 2025
 40. VA Handbook 6500.10, “Mobile Device Security Policy,” February 15, 2018
 41. VA Handbook 6500.11, “VA Firewall Configuration,” August 22, 2017
 42. OIT Process Asset Library (PAL), [OIT Process Asset Library](#).
 43. One-VA Technical Reference Model (TRM) (reference at <https://www.va.gov/trm/TRMHomePage.aspx>)
 44. VA Directive 6508, “Implementation of Privacy Threshold Analysis and Privacy Impact Assessment,” October 15, 2014
 45. VA Directive 6510, “VA Identity, Credential and Access Management,” September 3, 2024
 46. VA Handbook 6510, “VA Identity, Credential and Access Management,” September 27, 2024
 47. VA Directive and Handbook 6513, “Secure External Connections,” October 12, 2017
 48. VA Directive 6300, “Records and Information Management,” September 21, 2018
 49. VA Handbook, 6300.1, “Records Management Procedures,” March 24, 2010
 50. NIST SP 800-37 Rev 2, “Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy,” December 2018
 51. NIST SP 800-53 Rev. 5, “Security and Privacy Controls for Federal Information Systems and Organizations,” September 23, 2020 (includes updates as of 12/10/2020)
 52. VA Directive 0735, “Homeland Security Presidential Directive 12 (HSPD-12) Program,” October 26, 2015
 53. VA Handbook 0735, “Homeland Security Presidential Directive 12 (HSPD-12) Program,” March 24, 2014
 54. OMB Memorandum 05-24, “Implementation of Homeland Security Presidential Directive (HSPD) 12 – Policy for a Common Identification Standard for Federal Employees and Contractors,” August 5, 2005
 55. OMB Memorandum M-19-17, “Enabling Mission Delivery Through Improved Identity, Credential, and Access Management,” May 21, 2019
 56. OMB Memorandum, “Guidance for Homeland Security Presidential Directive (HSPD) 12 Implementation,” May 23, 2008
 57. Federal Identity, Credential, and Access Management (FICAM) Architecture, June 30, 2023 ([FICAM Architecture \(idmanagement.gov\)](#))
 58. NIST SP 800-116 Rev 1, “Guidelines for the Use of Personal Identity Verification (PIV) Credentials in Facility Access,” June 2018
 59. NIST SP 800-63-3, 800-63A, 800-63B, 800-63C, “Digital Identity Guidelines,” updated March 02, 2020
 60. NIST SP 800-157, “Guidelines for Derived PIV Credentials,” December 2014
 61. VA Memorandum, VAIQ #7100147, “Continued Implementation of Homeland Security Presidential Directive 12 (HSPD-12),” April 29, 2011 (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>)
 62. IAM Identity Management Business Requirements Guidance document, May 2013, (reference Enterprise Architecture Section, PIV/IAM (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>))

Teleradiology Physician Services

63. VA Memorandum “Personal Identity Verification (PIV) Logical Access Policy Clarification,” July 17, 2019, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>
64. Trusted Internet Connections (TIC) 3.0 Core Guidance Documents, <https://www.cisa.gov/publication/tic-30-core-guidance-documents>
65. OMB Memorandum M-19-26, “Update to the Trusted Internet Connections (TIC) Initiative,” September 12, 2019
66. OMB Memorandum M-08-23, “Securing the Federal Government’s Domain Name System Infrastructure,” August 22, 2008
67. Sections 524 and 525 of the Energy Independence and Security Act of 2007, (P.L. 110–140), December 19, 2007
68. Section 104 of the Energy Policy Act of 2005, (P.L. 109–58), August 8, 2005
69. Executive Order 13221, “Energy-Efficient Standby Power Devices,” August 2, 2001
70. VA Directive 0057, “VA Environmental Management Program,” October 25, 2022
71. Office of Information Security (OIS) VAIQ #7424808 Memorandum, “Remote Access,” January 15, 2014, <https://www.voa.va.gov/DocumentListPublic.aspx?NodeID=28>
72. Clinger-Cohen Act of 1996, 40 U.S.C. §11101 and §11103
73. “Veteran Focused Integration Process (VIP) Guide 4.0,” March 2021, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371>
74. VA Memorandum “Proper Use of Email and Other Messaging Services,” January 2, 2018, <https://www.voa.va.gov/DocumentListPublic.aspx?NodeID=28>
75. “Product Line Management Transformation Playbook” version 3.1, August 2023, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946>
76. NIST SP 500-267B Revision 1, “USGv6 Profile,” November 2020
77. OMB Memorandum M-21-07, “Completing the Transition to Internet Protocol Version 6 (IPv6),” November 19, 2020
78. Social Security Number (SSN) Fraud Prevention Act of 2017
79. Section 240 of the Consolidated Appropriations Act (CAA) 2018, March 23, 2018
80. C.F.R Title 15 Part 7, “Securing the Information and Communications Technology and Services (ICTS) Supply Chain”, as amended
81. Executive Order 14028, “Executive Order on Improving the Nation's Cybersecurity,” May 12, 2021, <https://bidenwhitehouse.archives.gov/briefing-room/presidential-actions/2025/01/16/executive-order-...>
82. OMB Memorandum M-22-09, “Moving the U.S. Government Toward Zero Trust Cybersecurity Principles”, January 26, 2022, <https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>.
83. NIST SP 800-52 Revision 2, “Guidelines for the Selection, Configuration, and Use of Transport Layer Security (TLS) Implementations
84. OMB M-22-18, “Enhancing the Security of the Software Supply Chain through Secure Software Development Practices,” September 14, 2022
85. OMB M-23-16, “Update to Memorandum M-22-18,” June 9, 2023
86. OMB M-21-31, “Improving the Federal Government’s Investigative and Remediation Capabilities Related to Cybersecurity Incidents,” August 27, 2021
87. NIST SP 800-88 Revision 1 “Guidelines for Media Sanitization,” December 2014
88. CISA Binding Operational Directive (BOD) 19-02: “Vulnerability Remediation Requirements of Internet-Accessible Systems,” April 29, 2019, [BOD 19-02: Vulnerability Remediation Requirements for Internet-Accessible Systems | CISA](https://www.cisa.gov/bod-19-02-vulnerability-remediation-requirements-for-internet-accessible-systems)

Teleradiology Physician Services

89. CISA BOD 22-01: "Reducing the Significant Risk of Known Exploited Vulnerabilities," November 3, 2021, [BOD 22-01: Reducing the Significant Risk of Known Exploited Vulnerabilities | CISA](#)
90. CISA BOD 23-01: Improving Asset Visibility and Vulnerability Detection on Federal Networks." Cybersecurity & Infrastructure Security Agency (CISA), [BOD 23-01: Improving Asset Visibility and Vulnerability Detection on Federal Networks | CISA](#)
91. VA Directive 6550, Pre-Procurement Assessment and Implementation of Medical Devices/Systems, June 03, 2019
92. VA Memorandum, "VA Security Controls," January 17, 2025, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>

3.0 SCOPE OF WORK

The National Teleradiology Program requires teleradiology services to support Veterans Affairs (VA) facilities nationwide in the interpretation of imaging exams. VA Radiology Services follow the standards and guidelines set forth by the American College of Radiology (ACR). A Contractor providing teleradiology services shall provide services that meet or exceed the American College of Radiology Guidelines <https://www.acr.org/Clinical-Resources/Clinical-Tools-and-Reference/Practice-Parameters-and-Technical-Standards>.

For the purpose of this contract, teleradiology is defined as the electronic transmission of radiological images from VHA Picture Archive and Communication System (PACS) and HL7 orders/reports to the Contractor for imaging exam interpretation and subsequent transmission of the imaging report back to the source facility's electronic medical record.

The Contractor shall provide teleradiology services in the following functional areas, as defined in PWS Section 5.0 below, which establishes all general requirements for the services performed under this contract. To ensure integration across the program, the Contractor shall coordinate with all stakeholders in the performance of orders placed against this contract.

The Contractor shall provide Board Certified or Board Eligible Radiology Physician Services in accordance with the specifications contained herein. The Contractor shall provide teleradiology services and support services consistent with Joint Commission, that meet or exceed VA and American College of Radiology Guidelines as defined further in this document.

Specifically, The Contractor shall furnish routine and STAT specialty and subspecialty interpretations of diagnostic imaging exams. In addition to providing final interpretations for approximately 138,000 examinations, it is expected The Contractor will develop a workflow to ensure the exams are interpreted within the turnaround times specified in section 5.1.5 of the contract. Based on the complexity and size of the facilities served by NTP, and the scope of the work performed, a dedicated pool of Board Certified or Board Eligible radiologists will be required for this contract. The Contractor shall have an

Teleradiology Physician Services

existing or be eligible to obtain a national Memorandum of Understanding (MOU)/Interconnection Security Agreement (ISA) between themselves and the VHA to allow for providing teleradiology services that conform to all VA security requirements. To ensure continuous maintenance of the network and the ability to transmit images from the NTP to The Contractor, it is necessary to have 24/7/365 support from The Contractor's Information Technology (IT) Service. In addition, The Contractor shall provide ongoing professional practice evaluations (OPPE) for all staff that meet the VA requirements of 100 exams per radiologist per year. All services must include assigned points of contact for all administrative, billing, technical, and quality functions.

The Contractor shall be responsible for providing interpretations of imaging examinations, including computed tomography/angiography scans (CT/CTA), digital x-ray (digital plain film), ultrasound (US), including vascular ultrasound (Doppler/Duplex) exams, and magnetic resonance imaging/angiography (MRI/MRA) exams.

The Contractor shall identify a single point of contact as the representative and program lead for all work done under this contract.

4.0 PERFORMANCE DETAILS

4.1 CONTRACT TYPE

Indefinite Delivery / Indefinite Quantity (IDIQ) period of performance is anticipated to be five (5) years from the date of award.

4.2 PERFORMANCE PERIOD

The Period of Performance (POP) is anticipated to be five (5) years from the date of award, inclusive of a 12-month base year plus four (4) 12-month option years.

4.3 PLACE OF PERFORMANCE

The place of performance under this PWS shall primarily be performed at Contractor facilities within and outside the continental United States (CONUS / non-foreign OCONUS).

4.4 VA HOURS OF OPERATION

Business Hours: Coverage is 24 hours a day, 7 days a week, 52 weeks a year, including all Federal holidays.

Federal holidays set by law (USC Title 5 Section 6103) that VA follows are outlined here: <https://www.opm.gov/policy-data-oversight/pay-leave/federal-holidays/#url=Overview>

5.0 SPECIFIC TASKS AND DELIVERABLES

The Contractor shall perform the following:

5.1 SERVICE MANAGEMENT

5.1.1 CONTRACTOR PROJECT MANAGEMENT PLAN

The Contractor shall deliver a Contractor Project Management Plan (CPMP) that lays out the Contractor's approach, timeline, and tools to be used in execution of the base contract. The CPMP should take the form of both a narrative and graphic format that displays the schedule, milestones, risks, and resource support. The CPMP shall also include a communications plan to demonstrate how the Contractor will coordinate and execute planned, routine, and ad hoc data collection reporting requests as identified within the PWS. In the CPMP, the Contractor shall also detail how coordination with other contractors supporting NTP will be managed.

The baseline CPMP shall be delivered within 30 business days after award and updated monthly thereafter. Additional Contractor Project Management requirements will be defined at the individual TO level

Deliverable:

- A. Contractor Project Management Plan

5.1.2 DIRECT PATIENT CARE – TELERADIOLOGY

Scope of care – The Contract physician(s) shall be responsible for providing, including, but not limited to: Physicians provided in satisfaction of this contract shall be required to perform their assigned duties with regard to all admitted patients, outpatients, and eligible beneficiaries regardless of underlying disease process or physical condition of such patients or beneficiaries.

The contract shall provide physicians who shall: The Contractor shall provide Board Certified or Board Eligible Radiologists to perform final teleradiology interpretation services. Examination images from VHA will be transmitted to The Contractor using the Digital Imaging and Communications in Medicine (DICOM) protocol and the Federal Information Processing Standard (FIPS) compliant encryption via site to site Virtual Private Network (VPN) tunnel. Upon receipt of the captured image(s) and patient information from VHA, The Contractor shall provide an interpretation of the exam. The workflow will be provided in writing once the contract is awarded.

The Contract physician(s) shall dictate all interpreted studies and reports will be transmitted electronically to VA's electronic health record (EHR) (VistA/Oracle Health). The Contract Radiologists will have control of the reporting process from dictation to report sign-off/electronic signature/approval. Report quality/content will follow ACR standards of report structure and communication of results. The Contract Radiologist(s) will immediately notify VA clinicians of critical findings in accordance with American College of Radiology (ACR) standards, VHA and the NTP "alert notification" Quality Assurance policies, and in a manner appropriate to the clinical urgency of the case.

Teleradiology Physician Services

If a serious medical condition is identified during the interpretation, the report shall be immediately called in telephonically to the requesting VA Provider.

All STAT exams, when properly identified, will be performed and the results communicated within 60 minutes of receipt of images. All STAT exams must be identified at or prior to receipt of the images by The Contractor.

Final routine examination interpretation and official signature will be electronically uploaded into the VA VISTA or Oracle Health EHR within 72 hours of the image being transmitted to the reading site.

Mechanisms must be in place to provide notification of test results for patients receiving care in accordance with VHA Directive 1088, Communicating Test Results to Providers and Patients.

Deliverable:

The Contractor shall be expected to perform on a per procedure basis annually beginning with the initial estimated quantity listed below with an expectation that the estimated quantity will increase +/- 5% yearly. VA will not need to guarantee any minimum image volume.

Schedule of Supplies/Services	(Reads/Studies) Estimated Quantity
Digital X-Rays (Plain Films)	71,000
Computed Tomography (CT Scans)	51,000
Magnetic Resonance Imaging (MRI Scans)	5,000
Ultrasound Scan (US Scans)	11,000

5.1.3 CONTRACTOR RESPONSIBILITIES

The Contractor shall provide staff for the services required according to the following:

1. License: The Contracted physician(s) assigned by The Contractor to perform the services covered by this contract shall have a current, full, and unrestricted license to practice medicine in any State, Territory, or Commonwealth of the United States, or in the District of Columbia.
 - a. All licenses held by the radiologist working on this contract shall be full and unrestricted licenses. Contract physicians who have current, full, and unrestricted licenses in one or more states, but who have, or ever had, a license restricted, suspended, revoked, voluntarily revoked, voluntarily surrendered, pending action, or denied upon

Teleradiology Physician Services

application for cause in accordance with 38 USC 7402(f) will not be considered for this service contract.

2. Board Certification: All contract physician(s) shall be Board Certified or Board Eligible. All continuing education courses required for maintaining certification must be up to date at all times. Documentation verifying current certification shall be provided by The Contractor to the VA COR on an annual basis for each year of contract performance.
3. Credentialing and Privileging: Credentialing and privileging shall be done in accordance with the provisions of VHA Directive 1084, VHA Directive 1100.20, and VHA Directive 1100.21 referenced above in section 2.0, APPLICABLE DOCUMENTS. The Contractor is responsible for ensuring that proposed physician(s) possess the requisite credentials enabling the granting of privileges.
 - a. No services shall be provided by any contract physician(s) prior to obtaining approval by the Facility Medical Executive Board and Medical Center Director.
 - b. If a contract physician(s) is not credentialed and privileged or has credentials/privileges suspended or revoked, The Contractor shall furnish an acceptable substitute without any additional cost to the government.
 - c. Contract licensed independent practitioners must be credentialed and privileged on behalf of the NTP through the VA Palo Alto Health Care System Medical Staff Office in accordance with Credentialing and Privileging Directives 1100.20 and 1100.21 and VHA Directive 1084.
 - d. In general, the credentialing process should be started at least 60-90 days in advance of estimated entry on duty. The time required for this process may be expedited when patient care needs are urgent.
 - e. The VA's Medical Staff Office, COR, or Human Resources Management Service will provide an instruction packet containing forms and a detailed listing of required documentation, including curriculum vitae, current references, signed release of information from the candidate, and statement that the candidate does not have any physical or mental health condition that would adversely affect his/her ability to carry out the assigned duties, and additional credentialing forms.
 - f. The Contractor's personnel/or candidate will also be required to make an application through the VetPro internet-based process. The

Teleradiology Physician Services

candidate will need to be enrolled in VetPro by the Credentialing Coordinator at the VA or by the Human Resources Management Service designee. The website address is:

<https://fcp.vetpro.org/Admin/Login/Index>

- g. It is The Contractor's responsibility to contact COR to request a package and instructions.
 - h. The Contractor must furnish a copy of its policy and procedures for credentialing and privileging to the Contracting Officer and COR for review to ensure these meet the VA's requirements for establishment of competence through these mechanisms.
4. Technical Proficiency: Contract physician(s) shall be technically proficient in the skills necessary to fulfill the government's requirements, including the ability to speak, understand, read, and write English fluently. The Contractor shall provide documents upon request of the CO/COR to verify current and ongoing competency, skills, certification, and/or licensure related to the provision of care, treatment, and/or services performed. The Contractor shall provide verifiable evidence of all educational and training experiences, including any gaps in educational history for all contract physician(s) and contract physician(s) shall be responsible for abiding by the Facility's Medical Staff ByLaws, rules, and regulations that govern medical staff behavior.
5. Continuing Medical Education (CME) Requirements: The Contractor shall provide the COR copies of current CMEs as required by Facility Bylaws or as requested by NTP. Contract physician(s) registered or certified by national/medical associations shall continue to meet the minimum standards for CME to remain current. The Contractor shall report CME hours to the credentials office for tracking. These documents are required for both privileging and re-privileging. Failure to provide shall result in loss of privileges for contract physician(s).
6. Training (VA MANDATORY): The Contractor shall meet all VA educational requirements and mandatory course requirements defined herein; all training must be completed by the contract physician(s) as required by the VA. In particular, The Contractor will ensure continuous compliance of all providers for the following training, which is required to maintain access to VA information systems:

Training	Frequency	Annual Hours
VA Privacy and Information Security Awareness and	Once per year	Learning Hours: 1.0

Teleradiology Physician Services

Rules of Behavior (TMS Course 10176)		
Privacy and HIPAA Focused Training (TMS course 10203)	Once per year	Learning Hours: 1.0

7. National Provider Identifier (NPI): NPI is a standard, unique 10-digit numeric identifier required by HIPAA. The Veterans Health Administration must use NPIs in all HIPAA-standard electronic transactions for individual (health care practitioners) and organizational entities (medical facilities). The Contractor shall have or obtain appropriate NPI and if pertinent, the Taxonomy Code confirmation notice issued by the Centers for Medicare and Medicaid Services (CMS) National Plan and Provider Enumeration System (NPPES) be provided to the Contracting Officer with the proposal.
8. Conflict of Interest: The Contractor and all contract physician(s) are responsible for identifying and communicating to the CO and COR conflicts of interest at the time of proposal and during the entirety of contract performance. At the time of proposal, the Contractor shall provide a statement which describes, in a concise manner, all relevant facts concerning any past, present, or currently planned interest (financial, contractual, organizational, or otherwise) or actual or potential organizational conflicts of interest relating to the services to be provided. The Contractor shall also provide statements containing the same information for any identified consultants or subcontractors who shall provide services. The Contractor must also provide relevant facts that show how it's organizational and/or management system or other actions would avoid or mitigate any actual or potential organizational conflicts of interest. These statements shall be in response to the VAAR provision 852.209-70 Organizational Conflicts of Interest.
9. Citizenship related Requirements:
 - a. The Contractor certifies that The Contractor shall comply with any and all legal provisions contained in the Immigration and Nationality Act of 1952, As Amended; its related laws and regulations that are enforced by Homeland Security, Immigration and Customs Enforcement and the U.S Department of Labor as these may relate to non-immigrant foreign nationals working under contract or subcontract for the Contractor while providing services to Department of Veterans Affairs patient referrals;
 - b. While performing services for the Department of Veterans Affairs, the Contractor shall not knowingly employ, contract or subcontract with

Teleradiology Physician Services

an illegal alien; foreign national non-immigrant who is in violation their status, as a result of their failure to maintain or comply with the terms and conditions of their admission into the United States. Additionally, The Contractor is required to comply with all "E-Verify" requirements consistent with "Executive Order 12989" and any related pertinent Amendments, as well as applicable Federal Acquisition Regulations.

- c. If The Contractor fails to comply with any requirements outlined in the preceding paragraphs or its Agency regulations, the Department of Veterans Affairs may, at its discretion, require that the foreign national who failed to maintain their legal status in the United States or otherwise failed to comply with the requirements of the laws administered by Homeland Security, Immigration and Customs Enforcement and the U.S Department of Labor, shall be prohibited from working at The Contractor's place of business that services Department of Veterans Affairs patient referrals; or other place where The Contractor provides services to veterans who have been referred by the Department of Veterans Affairs; and shall form the basis for termination of this contract for breach.
- d. This certification concerns a matter within the jurisdiction of an agency of the United States and the making of a false, fictitious, or fraudulent certification may render the maker subject to prosecution under 18 U.S.C. 1001.
- e. The Contractor agrees to obtain a similar certification from its subcontractors. The certification shall be made as part of the offerors response to the RFP using the subject attachment in Section D of the solicitation document.

10. Annual Office of Inspector General (OIG) Statement:

- a. In accordance with HIPAA and the Balanced Budget Act (BBA) of 1977, the Department of Health and Human Services (HHS) Office of Inspector General (OIG) has established a list of parties and entities excluded from Federal health care programs. Specifically, the listed parties and entities may not receive Federal Health Care program payments due to fraud and/or abuse of the Medicare and Medicaid programs.
- b. Therefore, Contractor shall review the HHS OIG List of Excluded Individuals/Entities on the HHS OIG web site at <http://oig.hhs.gov/exclusions/index.asp> to ensure that the proposed contract physician(s) are not listed. Contractor should note that any excluded individual or entity that submits a claim for reimbursement to a Federal health care program, or causes such a claim to be submitted, may be subject to a Civil Monetary Penalty (CMP) for each

Teleradiology Physician Services

item or service furnished during a period that the person was excluded and may also be subject to treble damages for the amount claimed for each item or service. CMP's may also be imposed against The Contractor that employ or enter into contracts with excluded individuals to provide items or services to Federal program beneficiaries.

- c. By submitting their proposal, The Contractor certifies that the HHS OIG List of Excluded Individuals/Entities has been reviewed and that The Contractors are and/or firm is not listed as of the date the offer/bid was signed.

11. Clinical/Professional Direction: The qualifications of Contractor personnel are subject to review by VA Medical Facility Chief of Staff (COS) or his/her clinical designee and approval by the Medical Facility Director as provided in VHA Directive 1100.20, VHA Directive 1100.21, and VHA Directive 1084. Clinical/Professional direction of all clinical personnel covered by this contract for quality purposes will be provided by the Facility Chief of Staff and/or the Executive Director of NTP, or their designee.
12. Non-Personal Healthcare Services: The parties agree that The Contractor and all contract physician(s) shall not be considered VA employees for any purpose.
13. Indemnification: The Contractor shall be liable for, and shall indemnify and hold harmless the Government against, all actions or claims for loss of or damage to property or the injury or death of persons, arising out of or resulting from the fault, negligence, or act or omission of The Contractor, its agents, or employees.
14. Prohibition Against Self-Referral: The Contractor's physicians are prohibited from referring VA patients to The Contractor's or their own practice(s).
15. Inherent Government Functions: Contractor and Contract physician(s) shall not perform inherently governmental functions. This includes, but is not limited to, determination of agency policy, determination of Federal program priorities for budget requests, direction and control of government employees (outside a clinical context), selection or non-selection of individuals for Federal Government employment including the interviewing of individuals for employment, approval of position descriptions and performance standards for Federal employees, approving any contractual documents, approval of Federal licensing actions and inspections, and/or determination of budget policy, guidance, and strategy.
16. No Employee status: The Contractor shall be responsible for protecting The Contract physician(s) furnishing services. To carry out this responsibility,

Teleradiology Physician Services

The Contractor shall provide or certify that the following is provided for all their staff providing services under the resultant contract:

- a. Workers' compensation
- b. Professional liability insurance
- c. Health examinations
- d. Income tax withholding, and Social Security payments.

17. Tort Liability: The Federal Tort Claims Act does not cover Contractor or contract physician(s). When a Contractor or contract physician(s) has been identified as a provider in a tort claim, The Contractor shall be responsible for notifying their legal counsel and/or insurance carrier. The Contractor must ensure that all contract physicians are covered by professional liability insurance that covers the health care services they provide to VA. Any settlement or judgment arising from a Contractor's (or contract physician(s)) action or non-action shall be the responsibility of The Contractor and/or insurance carrier.
18. Contingency Plan: Because continuity of care is an essential part of NTP services, The Contractor shall have a contingency plan in place to be utilized if Contract service physician(s) leave(s) Contractor's employment or is unable to continue performance in accordance with the terms and conditions of the resulting contract.
19. Substitution of Personnel: During the first ninety (90) calendar days of performance, The Contractor shall make NO substitutions of assigned personnel unless the substitution is necessitated by illness, death or termination of employment. The Contractor shall notify the CO, in writing, within 7 calendar day (s) after the occurrence of any of these events and provide the information required below. After 90 days, The Contractor shall submit the information required below to the CO at least 20 business days in advance of the effective date to approve or disapprove the proposed substitution.
- a. New personnel shall not commence work until all necessary security requirements have been fulfilled and resumes provided and accepted. The COR and the Contracting Officer will evaluate such requests and promptly notify The Contractor of approval or disapproval in writing.
 - b. The Contractor shall provide a detailed explanation of the circumstances necessitating the proposed substitutions, complete resumes for the proposed substitutes, and any additional information requested by the CO. Proposed substitutes shall have equal to or better qualifications to those of the persons being replaced.

Teleradiology Physician Services

- c. For temporary substitutions where the key person shall not be reporting to work for three consecutive workdays or more, The Contractor shall provide a qualified replacement for the key person. The substitute shall have comparable qualifications to the key person. Any period exceeding two weeks will require the procedure as stated above.

5.1.4 CONTINUITY OF SERVICES UNDER CONTRACT

The Contractor must provide continuity of services during the performance of this contract.

1. The Contractor is responsible for providing qualified personnel to read images. The VA must be informed at least 48 hours in advance if there will be a significant change in The Contractor's ability to perform to allow for planning of service coverage and workload distribution. Requirements will be provided to NTP and maintained by the Contractor.
2. The Contractor shall maintain open and professional communication with members of the VA NTP staff. The Contractor shall provide up-to-date points of contact to facilitate communication on clinical, technical and administrative issues. Clinical staff will be available by phone and/or pager 24/7. The Contractor will provide a schedule of radiologists with telephone numbers for consultation by VA technologists and referring physicians.
3. The Contractor shall provide a single phone number with a list of individuals who could be contacted to immediately resolve any difficulties experienced during the hours of teleradiology services and STAT studies after hours. The COR will ensure up-to-date rosters of staff are provided to The Contractor.
4. Tele-Communications
 - a. The Contractor will secure and maintain the site to site VPN between The Contractor's facility and the VA at the Contractor's expense...
 - b. The Contractor shall make provisions for the proper maintenance and functioning of all imaging, teleradiology and associated equipment, facilities and fixtures as may reasonably be required by Contract Physicians to perform services hereunder.
5. Integration with VHA PACS and EMR's
 - a. The Contractor will be responsible to configure and maintain all required DICOM services needed to support ingestion of VHA images from VHA PACS. Data will be exported in the format native to the source PACS and

Teleradiology Physician Services

VHA will not be responsible to provide any data normalization as part of the export process.

- b. The Contractor shall be responsible for HL7 testing and integration to the VA's EMR. These include VistA HL7 v2.3, VistA v2.4 and Oracle Health Federal Electronic Health Record (FEHR). The contractor shall be responsible for ongoing HL7 testing, validation and integration as VA moved from VistA to FEHR. Integration changes will be required as sites update their VistA links from v2.3 to v2.4. The Contractor shall be responsible for interface/integration changes within their teleradiology PACS to align with VA's HL7 specifications.

5.1.5 CONTRACTOR RESPONSIBILITIES

1. Clinical Personnel Required: The Contractor shall provide contract physician(s) who are competent, qualified per this performance work statement, and adequately trained to perform assigned duties.
2. Management and Supervision: The Contractor shall be responsible for their own supervision of day-to-day operations and services provided under this contract by the Contractor's staff.
 - a. The NTP will provide the Contractor policies, procedures, and processes necessary to allow cooperative functioning between The Contractor and NTP. Updates and refreshers will provide The Contractor upon request and when policy procedures or processes change.
 - b. The Contractor shall complete background investigations to ensure that employees do not have a record of criminal offenses or substantiated incidents of patient abuse.
3. Standards of Care: The contract physician(s)' care shall cover the range of Radiology services as would be provided in a state-of-the-art civilian medical facility, and the standard of care shall be of a quality, meeting or exceeding current recognized national standards as established by:
 - a. The American College of Radiology Guidelines:
<https://www.acr.org/Clinical-Resources/Clinical-Tools-and-Reference/Practice-Parameters-and-Technical-Standards>
 - b. ACR Practice Parameter for Communication of Diagnostic Imaging Findings: <https://gravitas.acr.org/PPTS/GetDocumentView?docId=74>
4. VA Standards: The Contractor shall provide timely interpretations on all previously listed modalities, including digital x-ray (digital plain films), Computed Tomography/Angiography (CT/CTA), Magnetic Resonance Imaging/Angiography (MRI/MRA), and Ultrasound (US). Turnaround times are defined by the exam

Teleradiology Physician Services

type and begin at the time of transmission of the case from NTP to The Contractor for interpretation. Turnaround times are based on the nature of the exam and the required response time by The Contractor.

- a. STAT exam turnaround time: Read within 60 minutes.
 - b. Routine exam turnaround time: Read within 72 hours.
5. The professional standards of Joint Commission :
<https://www.jointcommission.org/en-us/standards>
 6. The standards of the American Hospital Association (AHA):
<https://www.aha.org/type/ahahret-guides> and; the requirements as contained in this PWS.

5.1.6 MEDICAL RECORDS

1. Authorities: Contractor's physician(s) providing healthcare services to VA patients shall be considered as part of the Department Healthcare Activity and shall comply with the 5 U.S.C.552a (Privacy Act), 38 U.S.C. 5701 (Confidentiality of claimants records), 5 U.S.C. 552 (FOIA), 38 U.S.C. 5705 (Confidentiality of Medical Quality Assurance Records) 38 U.S.C. 7332 (Confidentiality of certain medical records), Title 5 U.S.C. § 522a (Records Maintained on Individuals) as well as 45 C.F.R. Parts 160, 162, and 164 (HIPAA).
2. HIPAA: This contract and its requirements meet exception in 45 CFR 164.502(e), and do not require a BAA in order for Covered Entity to disclose Protected Health Information to: a health care provider for treatment of VA patients. Based on this exception, a BAA is not required for this contract.
 - a. Health records generated by this contract or provided to the Contractor by the VA are covered by the VA Privacy Act system of records entitled 'Patient Medical Records-VA' (24VA10A7).
 - b. Contractor generated VA Patient records are the property of the VA and shall not be accessed, released, transferred, or destroyed except in accordance with applicable laws and regulations.
 - c. Contractor shall ensure that all records pertaining to medical care and services provided to VA patients are captured in the VA electronic health record system as required by VA policy.
3. Disclosure: Contractor's physician(s) may have access to patient medical records for the purpose of providing medical care and services to VA patients and performing services under the contract. VA authorizes The Contractor to discuss patient health information for coordination of care with community health care providers in compliance with VA regulations, HIPAA and VHA Directive 1605.01, Privacy and Release of Information. The VA will provide The Contractor with a

Teleradiology Physician Services

copy of VHA Directive 1907.01, Health Information Management and Health Records and VHA Directive 1605.1, Privacy and Release of Information. The penalties and liabilities for the unauthorized disclosure of VA patient information mandated by the statutes and regulations mentioned above, apply to The Contractor.

4. Professional Standards for Documenting Care: Care shall be appropriately documented in medical records in accordance with standard commercial practice and guidelines established by VHA Directive 1907.01 Health Information Management and Health Records:
https://www.va.gov/vhapublications/ViewPublication.asp?pub_ID=9235 and all guidelines provided by NTP.
 - a. All image interpretations will either meet or exceed established NTP standards of timeliness, accuracy, content and signature. Only VHA-approved abbreviations will be used for documentation of the patient health record. All imaging exam interpretations shall meet or exceed established standards of timeliness, accuracy, content, and signature. Only medical abbreviations from Joint Commission's National Patient Safety Goals, current edition, will be used for documentation of the patient health record.
 - b. Interpretations shall include the following information:
 - i. Patient's full name, SSN, date of birth, clinical history, exam case number (accession number), date of interpretation, requesting physician, exam type, interpretation, and signature of contract radiologist providing interpretation.
5. Release of Information: The VA shall maintain control of releasing any copies of patient health information or health records and will follow policies and standards as defined but not limited to Privacy Act requirements. Contractor will not release or disclose copies of records and will refer to all such requests to the Release of Information Department to NTP.
6. Management for Medical Records: National Archives and Records Administration record disposition requirements are found in [RCS 10-1 Chapter 6, 6000](#) series.
7. MEDICAL RECORDS/COMPUTERIZED RECORD SYSTEMS/ DISCLOSURE/ RECORD RETENTION: All records created from these actions shall be managed in accordance with Record Control Schedule (RCS) 10-1. Close attention shall be given to disposition schedule found in RCS 10-1 Chapter 4, 4000 series (General Record Schedule 1.1). Other records included but not limited to Chapter 1, 1180.15 and 1180.23 (GRS 1.1), Chapter 5, 5020.5 (GRS 5.4). There are some specific special contracting record schedules in RCS 10-1 for individual groups of records.

Teleradiology Physician Services

8. ADMINISTRATIVE: Must take part in medical staff functions as required to meet the standards of the Joint Commission.
9. Quality Assurance (QA)/Quality Improvement (QA/QI) documentation: The contract physician(s) shall complete the appropriate. Quality Management /Performance Improvement (QM/PI) documentation pertaining to all procedures, complications and outcome of examinations.
10. MEDICAL RECORDS REQUIREMENTS:
 - a. Authorities: Contractor providing treatment and healthcare services to VHA patients shall comply with 45 C.F.R. Parts 160, 162, and 164 (Health Insurance Portability and Accountability Act's Privacy Rule) and any other applicable law regarding health information, including contractual obligations.
 - b. Health records provided to The Contractor by the VA for the medical care and services to VA patients are covered by VHA Privacy Act system of records entitled 'Patient Medical Records-VA' 24VA10A7 at http://vaww.oprm.va.gov/docs/Current_SORN_List_11_13_2020.pdf Address and authority exists to disclosure these records to The Contractor for treatment purposes.
 - c. The Contractor generated patient medical records are the property of The Contractor and shall not be accessed, released, transferred, or destroyed except in accordance with applicable laws and regulations. Contractor shall ensure that copies of all health records pertaining to medical care and services provided to VHA patients are available for transmission and release when requested by VHA. As part of reimbursing the Contractor for medical care and services provided to VHA patients, copies of health records may be required for payment and quality reviews.

5.1.7 SYSTEM REQUIREMENTS

1. The contractor must maintain a teleradiology PACS that is reliable and functional to prevent any disruption in the delivery of services. Data security must be maintained at all times. Facility personnel must be notified immediately of any equipment malfunctions that would hinder the transmission of images.. The Contractor must specify the speeds of their image receiving equipment in the vendor proposal. Vendors must specify backup/disaster recovery plans are in place to ensure uninterrupted processing of NTP medical images.
2. The Contractor warrants that any data containing patient-specific identifiers will be handled in such a way as to prevent disclosure to unauthorized parties. This includes transmission of the data (from the point at which the data leaves the VA

Teleradiology Physician Services

network to the point at which the images are interpreted) as well as storage of the data by the Contractor. Contractor agrees to comply with all applicable data security laws and guidelines, as well as HIPAA and various Joint Commission provisions. The Contractor will provide utmost care and attention to patient data. All patients will be assured of their privacy and personal dignity in accordance with applicable laws, rules and regulations. All patient information remains the sole property of the US Government and may not be used for any purpose other than those stipulated in this agreement.

3. VA will act as the primary custodian of the patient information (including both the image data and the report) for all purposes related to VA and Government records retention requirements.
4. Patient information, including images, will be retained by the Contractor only for the minimum period of time required to comply with any applicable laws, and should then be purged according to NIST 800-88.
5. Upon request, Contractor will provide VA with access to information pertaining to the way in which The Contractor maintains VA patient data and the steps taken on an ongoing basis to ensure the privacy and security thereof. This includes, but is not limited to, information regarding computer network architecture, configuration of firewall(s), routers, and other pieces of networking equipment, information about installed security software, and audits of patches of known security vulnerabilities. All relevant security-related patches and anti-virus updates must be installed within 30 days of initial release.
6. Patient medical data transfer and storage complies with the American College of Radiology (ACR) and Digital Imaging and Communication of Medicine (DICOM) standards and meets and anticipates all current, known confidentiality requirements and regulations.
7. The Contractor radiologists shall be available to receive phone calls from the VAMCs' physicians (e.g. Emergency Room STAT requests after normal operating hours) in reference to the most appropriate study to perform in the given clinical situation. If an additional study is needed, the sending facility will be contacted by the respective Contractor's staff to communicate the need for the study.
8. The Contractor will provide a final report, which will be uploaded to the respective VHA's EHR and electronically signed by the interpreting radiologists.
9. The Contractor shall maintain its teleradiology PACS equipment in good working order and in accordance with the specifications of the manufacturer. Equipment quality control shall be performed in accordance with the manufacturer's specifications. Records of equipment quality control activities shall be made available to VA for review upon request.

Connectivity Management:

1. Network connection to VA shall be via a Site-to-Site Virtual Private Network (VPN) connected through a VA gateway. No costs for configurations, modifications, or upgrades to the VA network shall be incurred by The Contractor. The Contractor shall be responsible for all costs associated with implementing and maintaining their portion of the site-to-site VPN.
2. A secure, web-based method shall be used by The Contractor to provide the input and verification of patient data associated with transmitted image data.
3. The Contractor must maintain a system that is reliable and functional in order to prevent any disruption of delivery of service. Data transmission security must be maintained at all times. The Contractor shall have technical support available 24/7 to quickly resolve integration or connectivity issues, which may negatively impact the transmission of images or reports.
4. The Contractor must maintain validated HL7 connectivity for orders and reports with VA Vista HL7 2.3 and 2.4 formats as well as Oracle Health Federal Electronic Health Record (FEHR). The Contractor shall support updates to facility HL7 versions from 2.3 to 2.4 and the addition of site-specific accession numbers as they arise. The Contractor shall also support ongoing development/changes to the Oracle Health FEHR HL7 interface.

5.1.8 GOVERNMENT RESPONSIBILITIES

1. VA Support Personnel, Services or Equipment: The connectivity/functionality should be approved and verified by VA prior to acceptance. Teleradiology equipment, such as diagnostic workstations, firewalls, switches, routers, clients, and servers will be provided by the Contractor.
 - a. The contractor shall use a voice recognition system for radiology reporting. Training for users will be provided by The Contractor.
 - b. Reports shall be routed into the Vista/Oracle Health Patient Record and be signed electronically.
 - c. The Contractor shall be jointly responsible along with the VA NTP Chief Quality Officer in developing criteria for monitoring quality assurance, quality control, utilization review, procedures relevant to radiology services in order to assure compliance with the current JC standards. The Contractor will be required to furnish OPPE results at the time of credentialing and as required in deliverables.
 - d. Digital Imaging Communication of Medical (DICOM) images will be routed to Contractor via site-to-site VPN and will originate from VHA PACS.

Teleradiology Physician Services

Contractor shall be responsible for internal HL7 and DICOM data normalization to ensure that orders and reports are unambiguously associated with images for the correct patient.

- e. The Contractor shall track the source of the images by sending Application Entity Title (AET) for monthly volume and billing data. The Contractor shall make provisions for the proper maintenance and functioning of all government-furnished imaging, teleradiology and associated equipment, facilities and fixtures as may reasonably be required by Physicians to perform services hereunder.
 - f. The VA shall make available to Contractor copies of its internal policies, procedures, and necessary forms which physicians will require in performing their duties.
 - g. The VA warrants that the radiology departments meet or exceed all requirements for state licensing and any applicable accrediting or regulatory body, such as the Joint Commission.
 - h. The VA will use qualified personnel to operate equipment necessary to produce adequate images for interpretation.
2. Contract Administration/Performance Monitoring: After award of contract, all inquiries and correspondence relative to the administration of the contract shall be addressed to: the Contracting Officer (CO) and Contracting Officer Representative (COR), Clinical point of contact, and any other relevant personnel involved.

a. CO RESPONSIBILITIES: CO - *Name/Address/Phone/email*

- i. The Contracting Officer is the only person authorized to approve changes or modify any of the requirements of this contract. The Contractor shall communicate with the Contracting Officer on all matters pertaining to contract administration. Only the Contracting Officer is authorized to make commitments or issue any modification to include (but not limited to) terms affecting price, quantity or quality of performance of this contract.
- ii. The Contracting Officer shall resolve complaints concerning Contractor relations with the Government employees or patients. The Contracting Officer is final authority on validating complaints. In the event the Contractor effects any such change at the direction of any person other than the Contracting Officer without authority, no adjustment shall be made in the contract price to cover an increase in costs incurred as a result thereof.

Teleradiology Physician Services

- iii. In the event that contracted services do not meet quality and/or safety expectations, the best remedy will be implemented, to include but not limited to a targeted and time limited performance improvement plan; increased monitoring of the contracted services; consultation or training for Contractor personnel to be provided by the VA; replacement of the contract personnel and/or renegotiation of the contract terms or termination of the contract.

b. COR RESPONSIBILITIES: COR: *Name/Address/Phone/email*

- i. The COR shall be the VA official responsible for verifying contract compliance. After contract award, any incidents of Contractor noncompliance as evidenced by the monitoring procedures shall be forwarded immediately to the Contracting Officer.
- ii. The COR will be responsible for monitoring the Contractor's performance to ensure all specifications and requirements are fulfilled. Quality Improvement data that will be collected for ongoing monitoring includes but is not limited to: Timeliness of Reports, Provider Quality Performance, Network Uptime Metric, Privacy, Confidentiality and HIPAA.
- iii. The COR will maintain a record-keeping system of services by electronic record, quality assurance and surveillance. The COR will review this data monthly when invoices are received and certify all invoices for payment by comparing the procedures documented on the VA record-keeping system and those on the invoices. Any evidence of the Contractor's non-compliance as evidenced by the monitoring procedures shall be forwarded immediately to the Contracting Officer.
- iv. The COR will review and certify monthly invoices for payment. If in the event the Contractor fails to provide the services in this contract, payments will be adjusted to compensate the Government for the difference.
- v. All contract administration functions will be retained by the VA.

5.1.9 REPORTING REQUIREMENTS

The Contractor shall provide the VA PM/COR with Weekly, Monthly, and Quarterly reports in electronic format in Microsoft Word. The report shall include detailed instructions/explanations for each required report element, to ensure that data is accurate and consistent. These reports shall reflect data as of the last day of the preceding month.

Teleradiology Physician Services

Weekly reports shall include report turnaround times. Monthly Reports shall cover accuracy of interpretation of reports, list of radiologists providing services, including those who worked on the project, and identify anyone who has left the company, and the billing report of all work completed during the reporting period. Certificates of Completion for Cyber Security and Patient Privacy Training Courses must be provided before newly hired personnel receive an account on VA Network including annual training refreshes. Quarterly reports shall consist of Ongoing Professional Practice Evaluations (OPPE)

Additionally, The Contractor shall monitor performance against the Quality Control Program (QCP) Plan and report any deviations. It is expected that The Contractor will keep in communication with VA accordingly so that issues that arise are transparent to both parties to prevent the need for escalation of outstanding issues.

Downtime calculations will be defined as follows.

Deliverables:

- A. Certificates of Completion are due before receiving an account for new hires.
- B. Weekly Report due by COB Monday for the previous week.
- C. Monthly Report due by COB on the 5th day of every month during the period of performance.
- D. Quarterly Ongoing Professional Practice Evaluation (OPPE) Report due by COB on the 10th day every three months.

5.1.10 QUALITY CONTROL

The Contractor shall develop, maintain, and implement an effective QCP to ensure services are performed in accordance with this PWS. The Contractor shall create a QCP Plan that defines the procedures to identify, prevent, and ensure non-recurrence of defective services, and where relevant, establish a new process agreed upon by all stakeholders. The QCP is the means by which the Contractor assures that work complies with the requirements of the contract.

The QCP Plan shall be delivered within 30 business days after contract award and updated monthly thereafter.

Deliverable:

- A. Quality Control Program Plan

5.1.11 SECURITY AND PRIVACY REQUIREMENTS

POSITION/TASK RISK DESIGNATION LEVEL(S)

Position Sensitivity	Background Investigation (in accordance with Department of Veterans Affairs 0710 Handbook, "Personnel Suitability and Security Program," Appendix A)
----------------------	--

Teleradiology Physician Services

Low / Tier 1	Tier 1 / National Agency Check with Written Inquiries (NACI) A Tier 1/NACI is conducted by OPM and covers a 5-year period. It consists of a review of records contained in the OPM Security Investigations Index (SII) and the DOD Defense Central Investigations Index (DCII), Federal Bureau of Investigation (FBI) name check, FBI fingerprint check, and written inquiries to previous employers and references listed on the application for employment. In VA it is used for Non-sensitive or Low Risk positions.
Moderate / Tier 2	Tier 2 / Moderate Background Investigation (MBI) A Tier 2/MBI is conducted by OPM and covers a 5-year period. It consists of a review of National Agency Check (NAC) records [OPM Security Investigations Index (SII), DOD Defense Central Investigations Index (DCII), FBI name check, and a FBI fingerprint check], a credit report covering a period of 5 years, written inquiries to previous employers and references listed on the application for employment; an interview with the subject, law enforcement check; and a verification of the educational degree.
High / Tier 4	Tier 4 / Background Investigation (BI) A Tier 4/BI is conducted by OPM and covers a 10-year period. It consists of a review of National Agency Check (NAC) records [OPM Security Investigations Index (SII), DOD Defense Central Investigations Index (DCII), FBI name check, and a FBI fingerprint check report], a credit report covering a period of 10 years, written inquiries to previous employers and references listed on the application for employment; an interview with the subject, spouse, neighbors, supervisor, co-workers; court records, law enforcement check, and a verification of the educational degree.

The position sensitivity and the level of background investigation commensurate with the required level of access for the tasks within the Performance Work Statement are:

Position Sensitivity and Background Investigation Requirements

Tier1 / Low / NACI	Tier 2 / Moderate / MBI	Tier 4 / High / BI
☒	☐	☐
☒	☐	☐
☒	☐	☐

The resulting Position Sensitivity and Background Investigation requirements identify, in effect, the Background Investigation requirements for Contractor individuals, based upon the tasks the particular Contractor individual will be working. The submitted Contractor Staff Roster must indicate the required Background Investigation Level for each Contractor individual based upon the tasks the Contractor individual will be working, in accordance with their submitted proposal.

**6.0 VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY
LANGUAGE FOR INCLUSION INTO CONTRACTS, AS APPROPRIATE**

1. GENERAL

Contractors, contractor personnel, subcontractors, and subcontractor personnel shall be subject to the same Federal laws, regulations, standards, and VA Directives and Handbooks as VA and VA personnel regarding information and information system security.

2. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS

- a. A contractor/subcontractor shall request logical (technical) or physical access to VA information and VA information systems for their employees, subcontractors, and affiliates only to the extent necessary to perform the services specified in the contract, agreement, or task order.
- b. All contractors, subcontractors, and third-party servicers and associates working with VA information are subject to the same investigative requirements as those of VA appointees or employees who have access to the same types of information. The level and process of background security investigations for contractors must be in accordance with VA Directive and Handbook 0710, *Personnel Suitability and Security Program*. The Office for Operations, Security, and Preparedness is responsible for these policies and procedures.
- c. Contract personnel who require access to national security programs must have a valid security clearance. National Industrial Security Program (NISP) was established by Executive Order 12829 to ensure that cleared U.S. defense industry contract personnel safeguard the classified information in their possession while performing work on contracts, programs, bids, or research and development efforts. The Department of Veterans Affairs does not have a Memorandum of Agreement with Defense Security Service (DSS). Verification of a Security Clearance must be processed through the Special Security Officer located in the Planning and National Security Service within the Office of Operations, Security, and Preparedness.
- d. Custom software development and outsourced operations must be located in the U.S. to the maximum extent practical. If such services are proposed to be performed abroad and are not disallowed by other VA policy or mandates, the contractor/subcontractor must state where all non-U.S. services are provided and detail a security plan, deemed to be acceptable by VA, specifically to address mitigation of the resulting problems of communication, control, data protection, and so forth. Location within the U.S. may be an evaluation factor.
- e. The contractor or subcontractor must notify the Contracting Officer

immediately when an employee working on a VA system or with access to VA information is reassigned or leaves the contractor or subcontractor's employ. The Contracting Officer must also be notified immediately by the contractor or subcontractor prior to an unfriendly termination.

3. VA INFORMATION CUSTODIAL LANGUAGE

a. Information made available to the contractor or subcontractor by VA for the performance or administration of this contract or information developed by the contractor/subcontractor in performance or administration of the contract shall be used only for those purposes and shall not be used in any other way without the prior written agreement of the VA. This clause expressly limits the contractor/subcontractor's rights to use data as described in Rights in Data - General, FAR 52.227-14(d) (1).

b. VA information should not be co-mingled, if possible, with any other data on the contractors/subcontractor's information systems or media storage systems in order to ensure VA requirements related to data protection and media sanitization can be met. If co-mingling must be allowed to meet the requirements of the business need, the contractor must ensure that VA's information is returned to the VA or destroyed in accordance with VA's sanitization requirements. VA reserves the right to conduct on site inspections of contractor and subcontractor IT resources to ensure data security controls, separation of data and job duties, and destruction/media sanitization procedures are in compliance with VA directive requirements.

c. Prior to termination or completion of this contract, contractor/subcontractor must not destroy information received from VA, or gathered/created by the contractor in the course of performing this contract without prior written approval by the VA. Any data destruction done on behalf of VA by a contractor/subcontractor must be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, *Records and Information Management* and its Handbook 6300.1 *Records Management Procedures*, applicable VA Records Control Schedules, and VA Handbook 6500.1, *Electronic Media Sanitization*. Self-certification by the contractor that the data destruction requirements above have been met must be sent to the VA Contracting Officer within 30 days of termination of the contract.

d. The contractor/subcontractor must receive, gather, store, back up, maintain, use, disclose and dispose of VA information only in compliance with the terms of the contract and applicable Federal and VA information confidentiality and security laws, regulations and policies. If Federal or VA information confidentiality and security laws, regulations and policies become

Teleradiology Physician Services

applicable to the VA information or information systems after execution of the contract, or if NIST issues or updates applicable FIPS or Special Publications (SP) after execution of this contract, the parties agree to negotiate in good faith to implement the information confidentiality and security laws, regulations and policies in this contract.

e. The contractor/subcontractor shall not make copies of VA information except as authorized and necessary to perform the terms of the agreement or to preserve electronic information stored on contractor/subcontractor electronic storage media for restoration in case any electronic equipment or data used by the contractor/subcontractor needs to be restored to an operating state. If copies are made for restoration purposes, after the restoration is complete, the copies must be appropriately destroyed.

f. If VA determines that the contractor has violated any of the information confidentiality, privacy, and security provisions of the contract, it shall be sufficient grounds for VA to withhold payment to the contractor or third party or terminate the contract for default or terminate for cause under Federal Acquisition Regulation (FAR) part 12.

g. If a VHA contract is terminated for cause, the associated BAA must also be terminated and appropriate actions taken in accordance with VHA Handbook 1600.01, *Business Associate Agreements*. Absent an agreement to use or disclose protected health information, there is no business associate relationship.

h. The contractor/subcontractor must store, transport, or transmit VA sensitive information in an encrypted form, using VA-approved encryption tools that are, at a minimum, FIPS 140-2 validated.

i. The contractor/subcontractor's firewall and Web services security controls, if applicable, shall meet or exceed VA's minimum requirements. VA Configuration Guidelines are available upon request.

j. Except for uses and disclosures of VA information authorized by this contract for performance of the contract, the contractor/subcontractor may use and disclose VA information only in two other situations: (i) in response to a qualifying order of a court of competent jurisdiction, or (ii) with VA's prior written approval. The contractor/subcontractor must refer all requests for, demands for production of, or inquiries about, VA information and information systems to the VA contracting officer for response.

k. Notwithstanding the provision above, the contractor/subcontractor shall

not release VA records protected by Title 38 U.S.C. 5705, confidentiality of medical quality assurance records and/or Title 38 U.S.C. 7332, confidentiality of certain health records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse, or infection with human immunodeficiency virus. If the contractor/subcontractor is in receipt of a court order or other requests for the above mentioned information, that contractor/subcontractor shall immediately refer such court orders or other requests to the VA contracting officer for response.

I. For service that involves the storage, generating, transmitting, or exchanging of VA sensitive information but does not require C&A or an MOU-ISA for system interconnection, the contractor/subcontractor must complete a Contractor Security Control Assessment (CSCA) on a yearly basis and provide it to the COTR.

4. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

a. Information systems that are designed or developed for or on behalf of VA at non-VA facilities shall comply with all VA directives developed in accordance with FISMA, HIPAA, NIST, and related VA security and privacy control requirements for Federal information systems. This includes standards for the protection of electronic PHI, outlined in 45 C.F.R. Part 164, Subpart C, information and system security categorization level designations in accordance with FIPS 199 and FIPS 200 with implementation of all baseline security controls commensurate with the FIPS 199 system security categorization (reference Appendix D of VA Handbook 6500, *VA Information Security Program*). During the development cycle a Privacy Impact Assessment (PIA) must be completed, provided to the COTR, and approved by the VA Privacy Service in accordance with Directive 6507, *VA Privacy Impact Assessment*.

b. The contractor/subcontractor shall certify to the COTR that applications are fully functional and operate correctly as intended on systems using the VA Federal Desktop Core Configuration (FDCC), and the common security configuration guidelines provided by NIST or the VA. This includes Internet Explorer 7 configured to operate on Windows XP and Vista (in Protected Mode on Vista) and future versions, as required.

c. The standard installation, operation, maintenance, updating, and patching of software shall not alter the configuration settings from the VA approved and FDCC configuration. Information technology staff must also use the Windows Installer Service for installation to the default "program files" directory and silently install and uninstall.

Teleradiology Physician Services

- d. Applications designed for normal end users shall run in the standard user context without elevated system administration privileges.
- e. The security controls must be designed, developed, approved by VA, and implemented in accordance with the provisions of VA security system development life cycle as outlined in NIST Special Publication 800-37, *Guide for Applying the Risk Management Framework to Federal Information Systems*, VA Handbook 6500, *Information Security Program* and VA Handbook 6500.5, *Incorporating Security and Privacy in System Development Lifecycle*.
- f. The contractor/subcontractor is required to design, develop, or operate a System of Records Notice (SOR) on individuals to accomplish an agency function subject to the Privacy Act of 1974, (as amended), Public Law 93-579, December 31, 1974 (5 U.S.C. 552a) and applicable agency regulations. Violation of the Privacy Act may involve the imposition of criminal and civil penalties.
- g. The contractor/subcontractor agrees to:
 - (1) Comply with the Privacy Act of 1974 (the Act) and the agency rules and regulations issued under the Act in the design, development, or operation of any system of records on individuals to accomplish an agency function when the contract specifically identifies:
 - (a) The Systems of Records (SOR); and
 - (b) The design, development, or operation work that the contractor/subcontractor is to perform;
 - (2) Include the Privacy Act notification contained in this contract in every solicitation and resulting subcontract and in every subcontract awarded without a solicitation, when the work statement in the proposed subcontract requires the redesign, development, or operation of a SOR on individuals that is subject to the Privacy Act; and
 - (3) Include this Privacy Act clause, including this subparagraph (3), in all subcontracts awarded under this contract which requires the design, development, or operation of such a SOR.
- h. In the event of violations of the Act, a civil action may be brought against the agency involved when the violation concerns the design, development, or operation of a SOR on individuals to accomplish an agency function, and

Teleradiology Physician Services

criminal penalties may be imposed upon the officers or employees of the agency when the violation concerns the operation of a SOR on individuals to accomplish an agency function. For purposes of the Act, when the contract is for the operation of a SOR on individuals to accomplish an agency function, the contractor/subcontractor is considered to be an employee of the agency.

(1) "Operation of a System of Records" means performance of any of the activities associated with maintaining the SOR, including the collection, use, maintenance, and dissemination of records.

(2) "Record" means any item, collection, or grouping of information about an individual that is maintained by an agency, including, but not limited to, education, financial transactions, medical history, and criminal or employment history and contains the person's name, or identifying number, symbol, or any other identifying particular assigned to the individual, such as a fingerprint or voiceprint, or a photograph.

(3) "System of Records" means a group of any records under the control of any agency from which information is retrieved by the name of the individual or by some identifying number, symbol, or other identifying particular assigned to the individual.

i. The vendor shall ensure the security of all procured or developed systems and technologies, including their subcomponents (hereinafter referred to as "Systems"), throughout the life of this contract and any extension, warranty, or maintenance periods. This includes, but is not limited to workarounds, patches, hotfixes, upgrades, and any physical components (hereafter referred to as Security Fixes) which may be necessary to fix all security vulnerabilities published or known to the vendor anywhere in the Systems, including Operating Systems and firmware. The vendor shall ensure that Security Fixes shall not negatively impact the Systems.

j. The vendor shall notify VA within 24 hours of the discovery or disclosure of successful exploits of the vulnerability which can compromise the security of the Systems (including the confidentiality or integrity of its data and operations, or the availability of the system). Such issues shall be remediated as quickly as is practical, but in no event longer than 2 days.

k. When the Security Fixes involve installing third party patches (such as Microsoft OS patches or Adobe Acrobat), the vendor will provide written notice to the VA that the patch has been validated as not affecting the

Systems within 10 working days. When the vendor is responsible for operations or maintenance of the Systems, they shall apply the Security Fixes within 2 days.

I. All other vulnerabilities shall be remediated as specified in this paragraph in a timely manner based on risk, but within 60 days of discovery or disclosure. Exceptions to this paragraph (e.g. for the convenience of VA) shall only be granted with approval of the contracting officer and the VA Assistant Secretary for Office of Information and Technology.

5. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE, OR USE

a. For information systems that are hosted, operated, maintained, or used on behalf of VA at non-VA facilities, contractors/subcontractors are fully responsible and accountable for ensuring compliance with all HIPAA, Privacy Act, FISMA, NIST, FIPS, and VA security and privacy directives and handbooks. This includes conducting compliant risk assessments, routine vulnerability scanning, system patching and change management procedures, and the completion of an acceptable contingency plan for each system. The contractor's security control procedures must be equivalent to those procedures used to secure VA systems. A Privacy Impact Assessment (PIA) must also be provided to the COTR and approved by VA Privacy Service prior to operational approval. All external Internet connections to VA's network involving VA information must be reviewed and approved by VA prior to implementation.

b. Adequate security controls for collecting, processing, transmitting, and storing of Personally Identifiable Information (PII), as determined by the VA Privacy Service, must be in place, tested, and approved by VA prior to hosting, operation, maintenance, or use of the information system, or systems by or on behalf of VA. These security controls are to be assessed and stated within the PIA and if these controls are determined not to be in place, or inadequate, a Plan of Action and Milestones (POA&M) must be submitted and approved prior to the collection of PII.

c. Outsourcing (contractor facility, contractor equipment or contractor staff) of systems or network operations, telecommunications services, or other managed services requires certification and accreditation (authorization) (C&A) of the contractor's systems in accordance with VA Handbook 6500.3, *Certification and Accreditation* and/or the VA OCS Certification Program Office. Government-owned (government facility or government equipment) contractor-operated systems, third party or business partner networks require memorandums of understanding and interconnection agreements

Teleradiology Physician Services

(MOU-ISA) which detail what data types are shared, who has access, and the appropriate level of security controls for all systems connected to VA networks.

d. The contractor/subcontractor's system must adhere to all FISMA, FIPS, and NIST standards related to the annual FISMA security controls assessment and review and update the PIA. Any deficiencies noted during this assessment must be provided to the VA contracting officer and the ISO for entry into VA's POA&M management process. The contractor/subcontractor must use VA's POA&M process to document planned remedial actions to address any deficiencies in information security policies, procedures, and practices, and the completion of those activities. Security deficiencies must be corrected within the timeframes approved by the government. Contractor/subcontractor procedures are subject to periodic, unannounced assessments by VA officials, including the VA Office of Inspector General. The physical security aspects associated with contractor/subcontractor activities must also be subject to such assessments. If major changes to the system occur that may affect the privacy or security of the data or the system, the C&A of the system may need to be reviewed, retested and re-authorized per VA Handbook 6500.3. This may require reviewing and updating all of the documentation (PIA, System Security Plan, Contingency Plan). The Certification Program Office can provide guidance on whether a new C&A would be necessary.

e. The contractor/subcontractor must conduct an annual self assessment on all systems and outsourced services as required. Both hard copy and electronic copies of the assessment must be provided to the COTR. The government reserves the right to conduct such an assessment using government personnel or another contractor/subcontractor. The contractor/subcontractor must take appropriate and timely action (this can be specified in the contract) to correct or mitigate any weaknesses discovered during such testing, generally at no additional cost.

f. VA prohibits the installation and use of personally-owned or contractor/subcontractor-owned equipment or software on VA's network. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW or contract. All of the security controls required for government furnished equipment (GFE) must be utilized in approved other equipment (OE) and must be funded by the owner of the equipment. All remote systems must be equipped with, and use, a VA-approved antivirus (AV) software and a personal (host-based or enclave based) firewall that is configured with a VA-approved configuration. Software must be kept current, including all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-viral software and the firewall on the non-VA owned OE.

Teleradiology Physician Services

g. All electronic storage media used on non-VA leased or non-VA owned IT equipment that is used to store, process, or access VA information must be handled in adherence with VA Handbook 6500.1, *Electronic Media Sanitization* upon: (i) completion or termination of the contract or (ii) disposal or return of the IT equipment by the contractor/subcontractor or any person acting on behalf of the contractor/subcontractor, whichever is earlier. Media (hard drives, optical disks, CDs, back-up tapes, etc.) used by the contractors/subcontractors that contain VA information must be returned to the VA for sanitization or destruction or the contractor/subcontractor must self-certify that the media has been disposed of per 6500.1 requirements. This must be completed within 30 days of termination of the contract.

h. Bio-Medical devices and other equipment or systems containing media (hard drives, optical disks, etc.) with VA sensitive information must not be returned to the vendor at the end of lease, for trade-in, or other purposes. The options are:

(1) Vendor must accept the system without the drive;

(2) VA's initial medical device purchase includes a spare drive which must be installed in place of the original drive at time of turn-in; or

(3) VA must reimburse the company for media at a reasonable open market replacement cost at time of purchase.

(4) Due to the highly specialized and sometimes proprietary hardware and software associated with medical equipment/systems, if it is not possible for the VA to retain the hard drive, then;

(a) The equipment vendor must have an existing BAA if the device being traded in has sensitive information stored on it and hard drive(s) from the system are being returned physically intact; and

(b) Any fixed hard drive on the device must be non-destructively sanitized to the greatest extent possible without negatively impacting system operation. Selective clearing down to patient data folder level is recommended using VA approved and validated overwriting technologies/methods/tools. Applicable media sanitization specifications need to be pre-approved and described in the purchase order or contract.

(c) A statement needs to be signed by the Director (System Owner) that states that the drive could not be removed and that (a) and (b) controls above are in place and completed. The ISO needs to maintain the documentation.

6. SECURITY INCIDENT INVESTIGATION

- a. The term “security incident” means an event that has, or could have, resulted in unauthorized access to, loss or damage to VA assets, or sensitive information, or an action that breaches VA security procedures. The contractor/subcontractor shall immediately notify the COTR and simultaneously, the designated ISO and Privacy Officer for the contract of any known or suspected security/privacy incidents, or any unauthorized disclosure of sensitive information, including that contained in system(s) to which the contractor/subcontractor has access.
- b. To the extent known by the contractor/subcontractor, the contractor/subcontractor’s notice to VA shall identify the information involved, the circumstances surrounding the incident (including to whom, how, when, and where the VA information or assets were placed at risk or compromised), and any other information that the contractor/subcontractor considers relevant.
- c. With respect to unsecured protected health information, the business associate is deemed to have discovered a data breach when the business associate knew or should have known of a breach of such information. Upon discovery, the business associate must notify the covered entity of the breach. Notifications need to be made in accordance with the executed business associate agreement.
- d. In instances of theft or break-in or other criminal activity, the contractor/subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG and Security and Law Enforcement. The contractor, its employees, and its subcontractors and their employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The contractor/subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.

7. LIQUIDATED DAMAGES FOR DATA BREACH

- a. Consistent with the requirements of 38 U.S.C. §5725, a contract may require access to sensitive personal information. If so, the contractor is liable to VA for liquidated damages in the event of a data breach or privacy incident involving any SPI the contractor/subcontractor processes or maintains under this contract.

Teleradiology Physician Services

- b. The contractor/subcontractor shall provide notice to VA of a “security incident” as set forth in the Security Incident Investigation section above. Upon such notification, VA must secure from a non-Department entity or the VA Office of Inspector General an independent risk analysis of the data breach to determine the level of risk associated with the data breach for the potential misuse of any sensitive personal information involved in the data breach. The term 'data breach' means the loss, theft, or other unauthorized access, or any access other than that incidental to the scope of employment, to data containing sensitive personal information, in electronic or printed form, that results in the potential compromise of the confidentiality or integrity of the data. Contractor shall fully cooperate with the entity performing the risk analysis. Failure to cooperate may be deemed a material breach and grounds for contract termination.
- c. Each risk analysis shall address all relevant information concerning the data breach, including the following:
 - i. Nature of the event (loss, theft, unauthorized access);
 - ii. Description of the event, including:
 - 1. date of occurrence;
 - 2. data elements involved, including any PII, such as full name, social security number, date of birth, home address, account number, disability code;
 - iii. Number of individuals affected or potentially affected;
 - iv. Names of individuals or groups affected or potentially affected;
 - v. Ease of logical data access to the lost, stolen or improperly accessed data in light of the degree of protection for the data, e.g., unencrypted, plain text;
 - vi. Amount of time the data has been out of VA control;
 - vii. The likelihood that the sensitive personal information will or has been compromised (made accessible to and usable by unauthorized persons);
 - viii. Known misuses of data containing sensitive personal information, if any;
 - ix. Assessment of the potential harm to the affected individuals;

Teleradiology Physician Services

x. Data breach analysis as outlined in 6500.2 Handbook, *Management of Security and Privacy Incidents*, as appropriate; and

xi. Whether credit protection services may assist record subjects in avoiding or mitigating the results of identity theft based on the sensitive personal information that may have been compromised.

d. Based on the determinations of the independent risk analysis, the contractor shall be responsible for paying to the VA liquidated damages in the amount of \$37.50 per affected individual to cover the cost of providing credit protection services to affected individuals consisting of the following:

(1) Notification;

(2) One year of credit monitoring services consisting of automatic daily monitoring of at least 3 relevant credit bureau reports;

(3) Data breach analysis;

(4) Fraud resolution services, including writing dispute letters, initiating fraud alerts and credit freezes, to assist affected individuals to bring matters to resolution;

(5) One year of identity theft insurance with \$20,000.00 coverage at \$0 deductible; and

(6) Necessary legal expenses the subjects may incur to repair falsified or damaged credit records, histories, or financial affairs.

8. SECURITY CONTROLS COMPLIANCE TESTING

On a periodic basis, VA, including the Office of Inspector General, reserves the right to evaluate any or all of the security controls and privacy practices implemented by the contractor under the clauses contained within the contract. With 10 working-day's notice, at the request of the government, the contractor must fully cooperate and assist in a government-sponsored security controls assessment at each location wherein VA information is processed or stored, or information systems are developed, operated, maintained, or used on behalf of VA, including those initiated by the Office of Inspector General. The government may conduct a security control assessment on shorter notice (to include unannounced assessments) as determined by VA in the event of a security incident or at any other time.

9. TRAINING

- a. All contractor employees and subcontractor employees requiring access to VA information and VA information systems shall complete the following before being granted access to VA information and its systems:

- (1) Sign and acknowledge (either manually or electronically) understanding of and responsibilities for compliance with the *Contractor Rules of Behavior*, Appendix E relating to access to VA information and information systems;

- (2) Successfully complete the *VA Cyber Security Awareness and Rules of Behavior* training and annually complete required security training;

- (3) Successfully complete the appropriate VA privacy training and annually complete required privacy training; and

- (4) Successfully complete any additional cyber security or privacy training, as required for VA personnel with equivalent information system access *[to be defined by the VA program official and provided to the contracting officer for inclusion in the solicitation document – e.g., any role-based information security training required in accordance with NIST Special Publication 800-16, Information Technology Security Training Requirements.]*

- b. The contractor shall provide to the contracting officer and/or the COTR a copy of the training certificates and certification of signing the Contractor Rules of Behavior for each applicable employee within 1 week of the initiation of the contract and annually thereafter, as required.

- c. Failure to complete the mandatory annual training and sign the Rules of Behavior annually, within the timeframe required, is grounds for suspension or termination of all physical or electronic access privileges and removal from work on the contract until such time as the training and documents are complete.